# Contexto del proyecto — Aegis CyberAudit

> Última actualización: 2026-08-14. Este documento da una vista rápida y honesta del estado real del proyecto. Para detalle técnico exhaustivo (endpoints, decisiones de diseño, limitaciones línea por línea) ver `README.md` — este archivo es el resumen para orientarse rápido.

## 1. Qué es

Aegis CyberAudit es una plataforma SaaS B2B multi-tenant de auditoría de ciberseguridad para pymes: un CISO, consultor o responsable de compliance registra los activos de su organización (dominios, IPs), corre un escaneo técnico de perímetro (Nmap + TLS + cabeceras HTTP), sube evidencia documental contra un marco normativo elegido, y descarga un reporte ejecutivo en PDF con puntaje de riesgo y matriz de cumplimiento.

Marcos normativos soportados: **ISO 27001, NIST CSF, GDPR, normativa local de protección de datos, y Ley N° 21.663 de Chile (ANCI)** — esta última con controles técnicos que se satisfacen automáticamente contra los hallazgos del escaneo, sin pedir evidencia documental para esa parte.

---

## 2. Stack técnico

| Capa | Tecnología |
|---|---|
| Backend | Node.js + Express 5 + TypeScript (ESM), en `src/` |
| Frontend | Next.js 16 (App Router) + TypeScript + Tailwind v4 + shadcn/ui, en `frontend/` |
| Base de datos | PostgreSQL vía Supabase, con Row Level Security en casi todas las tablas |
| Auth | Supabase Auth (email/password + Google OAuth) — **no** JWT secret propio, se valida contra `auth.getUser()` de Supabase |
| Storage | Supabase Storage — evidencias cifradas AES-256-GCM, reportes vía signed URL de 1 hora |
| Colas de jobs | BullMQ + Redis (Upstash) — un worker por cola, procesos separados del API |
| Motor de escaneo | Nmap real (no simulado) invocado por `scanWorker` |
| i18n | Diccionarios propios es/en (sin librería externa) |
| Tests | Jest + Supertest, integración real contra Supabase (sin mocks) |

## 3. Arquitectura multi-tenant

Aislamiento entre organizaciones garantizado a nivel de **motor de base de datos** (RLS filtrando por `organization_id`), no solo en código de aplicación — un bug en una ruta no puede filtrar datos entre tenants. Roles: `ciso` (control total), `auditor`, `auditor_guest` (Piloto Invitado, 10 días, con cuotas), `viewer`. Aparte existe un flag `is_platform_admin` (no es un rol, es un booleano ortogonal) que da acceso a `/admin` — solo se otorga corriendo `npm run admin:promote` localmente con la `service_role` key, nunca desde la UI ni un endpoint.

---

## 4. Módulos principales

- **Activos (`/assets`)**: registro de IP pública o dominio (los únicos dos tipos que el modal de alta ofrece hoy — ver sección 6). Verificación de propiedad obligatoria antes de poder escanear: dominios vía registro DNS TXT (con hasta 5 reintentos automáticos en segundo plano durante 24h, además del botón manual "Verificar ahora"), IPs vía autoatestación de un `ciso`. Límite duro de **5 activos por organización**.
- **Auditorías (`/audits`)**: se crean eligiendo un framework. El **Módulo A** (escaneo técnico de red, Nmap real, cero archivos/cero credenciales, con modal de confirmación legal — Ley N° 21.459 — antes de lanzar) y el **Módulo B** (carga opcional de evidencia documental Excel/PDF/JSON) están claramente separados en la UI para no confundir a un usuario no técnico sobre qué requiere cada uno.
- **Hallazgos y falsos positivos (`/audits/[id]/report`)**: cada hallazgo se puede marcar `false_positive` o `accepted_risk` con justificación obligatoria (mínimo 10 caracteres) y un selector de motivo predefinido que precarga el texto (Riesgo Aceptado / Control Compensatorio / Entorno de Pruebas / Otro). Quedan en una pestaña aparte ("Alertas Ignoradas") con reactivación de 1 clic, y en su propia sección del PDF con quién los descartó y por qué.
- **Reportes PDF**: puntaje de riesgo (0-100, penalizado por severidad de hallazgos y cobertura documental incompleta), matriz ANCI cuando aplica, desglose de hallazgos activos, sección de excepciones aplicadas, hash SHA-256 de integridad (explícitamente **no** es firma electrónica avanzada). URL de descarga firmada, expira en 1 hora.
- **Módulo de simulación / sandbox** (botón en el dashboard): crea una auditoría de prueba y dispara un **escaneo Nmap real** contra `scanme.nmap.org` (target público que el propio proyecto Nmap autoriza para pruebas) — nunca hallazgos fabricados. Se puede limpiar con un clic (borra audit + hallazgos + el activo de prueba).
- **Dashboard**: hero de bienvenida guiado para cuentas sin auditorías (descartable), Puntaje de Salud de Seguridad como tarjeta destacada, banner de alerta si hay hallazgos críticos sin resolver, tarjetas de Dominio/IP a auditar, cumplimiento ANCI y falsos positivos/excepciones.
- **Admin (`/admin`, solo `is_platform_admin`)**: gestión directa de usuarios y organizaciones, KPIs de negocio, audit logs inmutables (sin policy de `UPDATE` / `DELETE` para ningún rol), FinOps interno (costos reales estimados por organización/auditoría, simulador de punto de equilibrio), retención GDPR configurable con purga autónoma.

- **Notificaciones por email**: al completar un escaneo (con aviso destacado si hubo hallazgos críticos) y para delegar la verificación DNS a un equipo de TI. Todas siguen el patrón **"preparado pero no conectado"**: sin `RESEND_API_KEY` configurada, el contenido se registra en el log del servidor en vez de enviarse de verdad — el código ya está listo para el día que se configure un proveedor real.

---

## 5. Reglas de negocio y seguridad ya implementadas

- Ningún endpoint permite auto-otorgarse organización, rol o `platform_admin`.
- Un dominio no verificado nunca puede pedirse en un escaneo — bloqueo explícito ( `403 UNAUTHORIZED_SCAN_TARGET` ) más registro del intento en `audit_logs`, no un descarte silencioso.
- Sesión: interceptor de refresh-and-retry ante un 401, con redirect global a `/login` (mensaje explicando por qué) solo cuando el refresh también falla — nunca para el caso "todavía no tenés perfil" (ese va a `/onboarding`, no a `/login`).
- Rate limiting general + uno más estricto en acciones sensibles (subir evidencia, lanzar escaneo, resetear contraseña).
- Evidencias cifradas AES-256-GCM antes de subir a Storage; buckets privados en todos los casos.

---

## 6. Estado actual / qué se hizo en las últimas fases

El desarrollo avanzó por "Fases" (ver `git log`), cada una implementando un prompt de especificación ( `a.md`, que se reescribe con cada pedido nuevo — no es un historial, es el prompt vigente en cada momento). Las últimas fases del proyecto (7, 8 y 9) cubrieron: accesibilidad del modal de registro de activos; persistencia de sesión y manejo de contraseñas; verificación DNS guiada; limpieza de un campo fantasma (RUT, nunca capturado por ningún formulario); manejo robusto de errores 401; rediseño completo del dashboard (hero de bienvenida, puntaje de salud, tarjetas); tema visual azul/slate consolidado en modo claro y oscuro; módulo de simulación con escaneo Nmap real; y reglas de negocio del MVP (límite de activos, notificaciones, reintentos DNS, modal híbrido de falsos positivos).

Varios de esos prompts asumían una arquitectura distinta a la real (ej. pedir Firebase Auth cuando la app usa Supabase Auth, o una tabla `exceptions_whitelist` que no existe) — en esos casos se implementó la intención real del pedido sobre la arquitectura que efectivamente existe, y se documentó la desviación en el README en vez de forzar un cambio destructivo o inventar algo que no encaja.

---

## 7. Limitaciones conocidas (a propósito, no descuidos)

- **Sin pasarela de pagos real**: los "planes" (Starter/Pro/Custom) son una etiqueta administrativa editable desde `/admin`, no hay facturación ni gating de funcionalidad por plan todavía.
- **Emails no conectados a un proveedor real** (ver sección 4) — falta solo configurar `RESEND_API_KEY`, el código y las plantillas ya están.
- **El worker de escaneo requiere `nmap` instalado** donde corra; sin él, el escaneo falla de forma prolija (audit queda `failed` ) en vez de crashear.

- **Selector de tipo de activo limitado a IP pública y Dominio**: se sacaron `Repositorio Git`, `Servidor Cloud` y `Rango CIDR` del modal de alta por pedido explícito (generaban desconfianza sobre acceso a código/credenciales) — siguen soportados a nivel de schema/backend, solo no se pueden crear desde ese modal.
- **Costos FinOps son una estimación** calculada de uso real registrado, no hay integración de facturación en vivo con los proveedores.

---

## 8. Dónde mirar para más detalle

- `README.md` — referencia técnica completa: setup desde cero, variables de entorno, todos los endpoints, decisiones de diseño explicadas con su motivo, limitaciones conocidas.
- `arquitectura-mvp.md` — diseño de arquitectura del MVP.
- `ESTADO_EJECUTIVO_Y_NEGOCIO.md` — brief ejecutivo (propuesta de valor, modelo económico, riesgo) — **desactualizado** a la fecha de este documento (quedó en la Fase 3), útil para el pitch de negocio pero no para el estado técnico actual.
- `DASHBOARD_FINOPS_INTERNO.md` — detalle del simulador de FinOps interno.